Technical Risk Treatment: Implementing and Validating Security Controls

GRC103 Risk Assessment and Management Techniques - Module 3 practical

Student	Chioma Ameh
Registration number	C11/26/CGRCE/17567
Institution	ICDFA
Scenario	Northbridge Services (fictional) internal document server
Date	10 November 2026
GitHub evidence	https://github.com/ChiomaAmeh/grc103-technical-risk-treatment-lab
Recorded demonstration	[TO COMPLETE: paste the link to the screen recording]

Honesty statement. Technical results in this report are measured outputs from my own isolated laboratory (Ubuntu Server and Kali Linux on a VirtualBox host-only network, fictional data only). Approvals, the managed-backup offer, costs and annual-loss figures are **simulated or assumed** and are labelled as such. Where a log line or test was not collected, this report says so instead of inventing it.

1. Laboratory environment and method

Item	Value
Host	HP laptop, Intel Core i7 8th gen, Windows 11 Pro; Oracle VirtualBox
Target VM	Ubuntu Server 24.04.5 LTS (2 vCPU, 2 GB RAM, 25 GB disk); hostname *ubuntu*; host-only address **192.168.56.20** (enp0s8)
Tester VM	Kali Linux 2025.4; host-only address **192.168.56.101** (eth1)
Network	VirtualBox Host-Only Ethernet Adapter (isolated). A second host-only address, 192.168.56.30, was added temporarily on Kali to act as an unapproved source.
Software	Nginx 1.24.0, UFW 0.36.2, Python 3.12 (legacy endpoint), curl 8.x, nmap 7.95
Data	Fictional only: *DUMMY RECORD A001 - training only*

NAT handling. Ubuntu's NAT adapter (enp0s3) was used only to install packages. The exposed services were created and the NAT interface was then taken down (`sudo ip link set enp0s3 down`) before any baseline scan, so all tests ran on the isolated host-only network. Kali's NAT adapter stayed connected only to push evidence to GitHub.

Method note (console limitation). The VirtualBox text console cannot paste, so long command sequences were saved as small helper scripts (`scripts/u1_build.sh ... u7_ship.sh`) on Kali, downloaded to Ubuntu over the host-only network, and run on the Ubuntu console. Kali-side tests are in `scripts/kali_tests.sh`. Every script is in the repository so the steps can be reviewed or repeated. Ubuntu was administered through the VM console while firewall rules were changed.

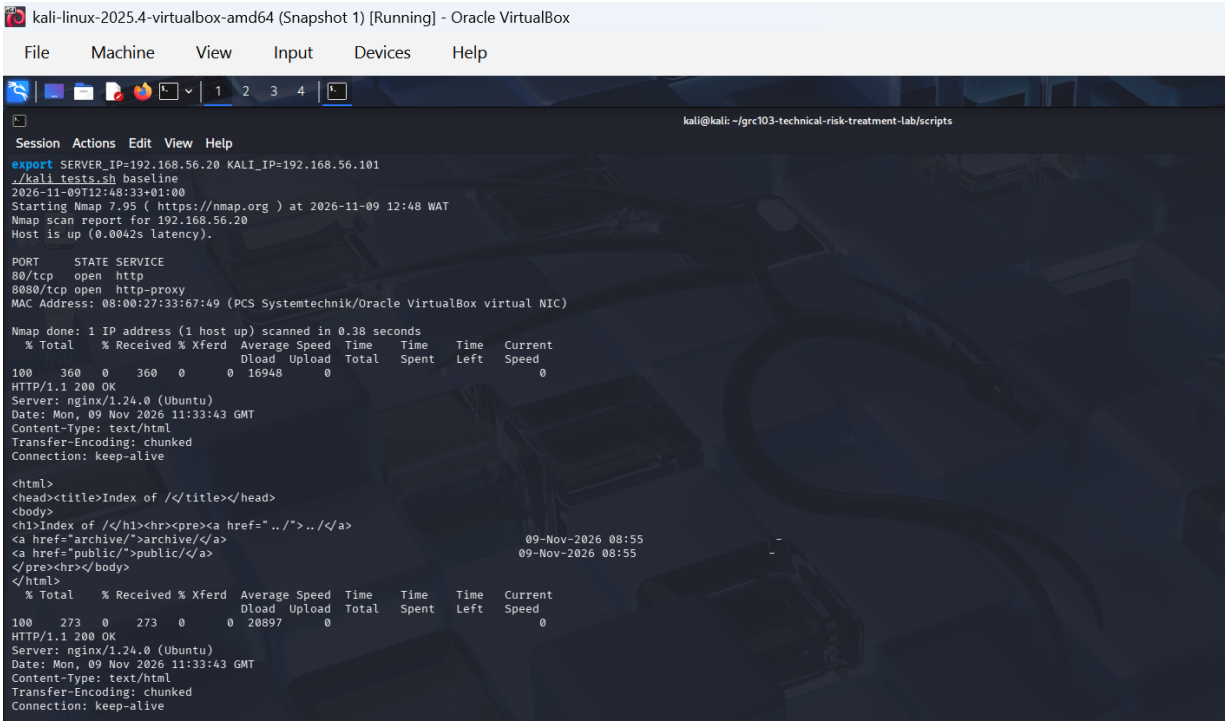
Checkpoint. [TO COMPLETE: name of the clean snapshot taken before the lab and screenshot 03, e.g. Ubuntu 'baseline-before-treatment'.]

Clock limitation. Ubuntu had no internet time sync (NAT down), so its clock drifted and stopped while the VM was paused. The offset to Kali was therefore measured per test group (about 4 to 15 minutes on 9 Nov; about 8 h 45 min to 8 h 57 min on 10 Nov). Log lines are matched by source address, request sequence and spacing as well as by time.

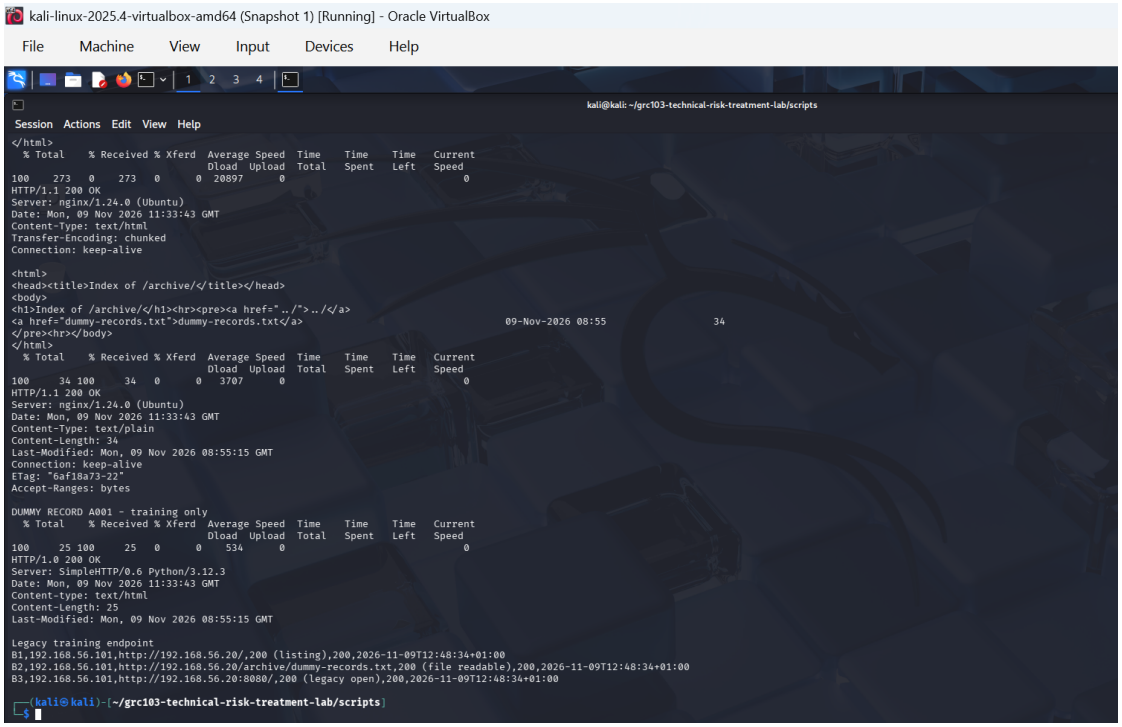
2. Baseline assessment and risk register

Before any change I scanned and probed the server from Kali (`./kali_tests.sh baseline`, 9 Nov 2026 12:48 WAT). An earlier run was discarded because it was taken before the services existed.

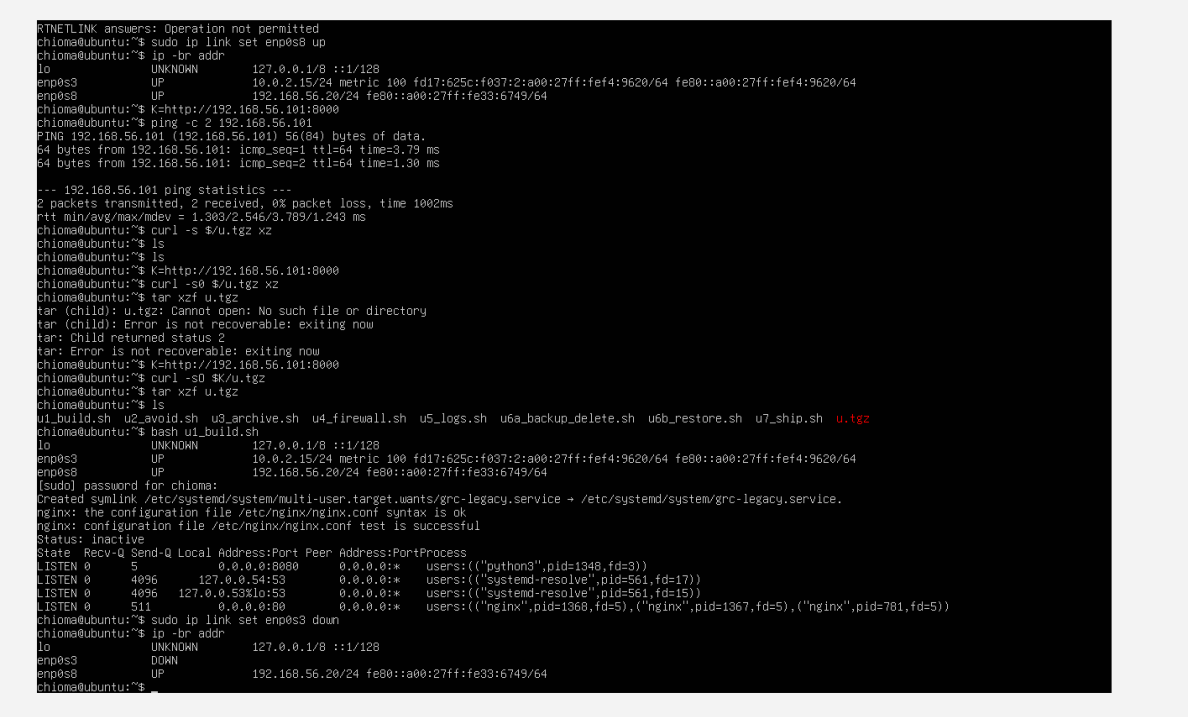
Test	Result observed
nmap -p 80,8080	80/tcp open (http), 8080/tcp open (http-proxy)
GET /	HTTP 200, Nginx directory listing showing archive/ and public/
GET /archive/	HTTP 200, listing of dummy-records.txt
GET /archive/dummy-records.txt	HTTP 200, 'DUMMY RECORD A001 - training only'
GET :8080/	HTTP 200 from Python SimpleHTTP/0.6, 'Legacy training endpoint' (no business need)
Ubuntu: ufw status	inactive (no network restriction)
Ubuntu: ss -lntp	0.0.0.0:8080 (python3) and 0.0.0.0:80 (nginx) listening



Screenshot 06 - baseline: ports 80 and 8080 open; browsable directory listing.



Screenshot 07 - baseline: dummy record readable, legacy endpoint answering, B1-B3 = 200.



Screenshot 05 - Ubuntu: :80 and :8080 listening, UFW inactive, NAT interface down, host-only up.

2.1 Risk register (baseline)

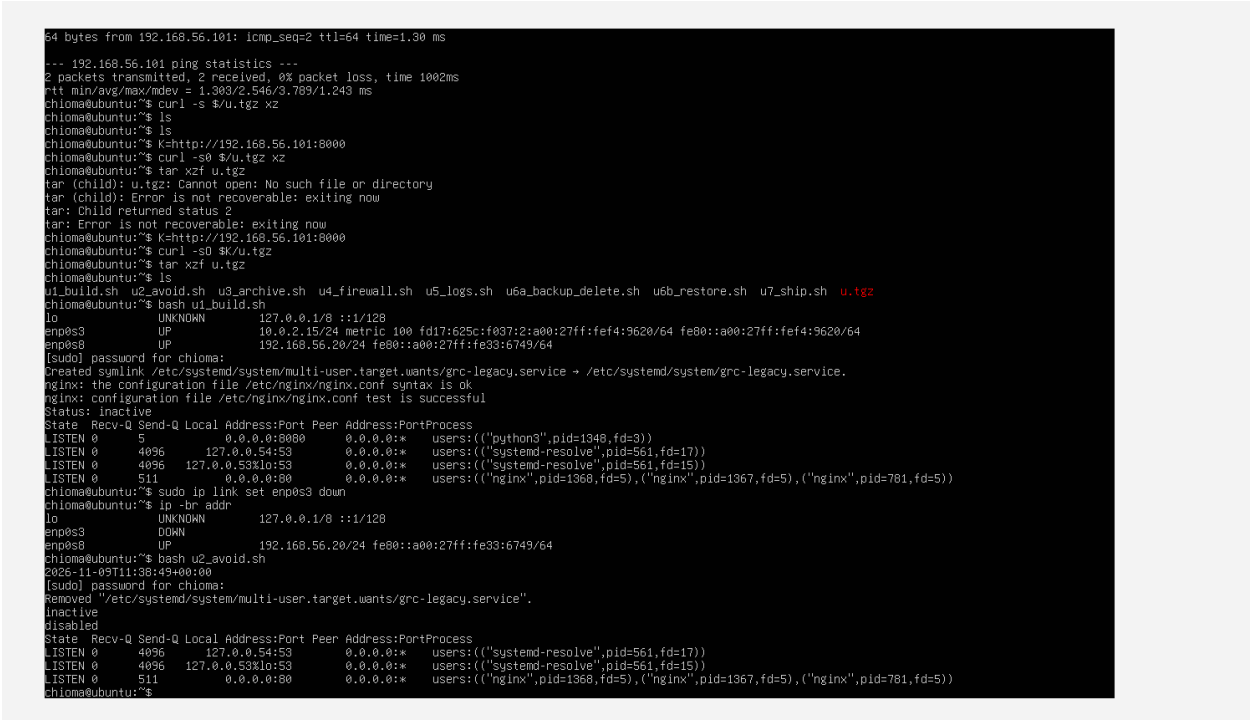
Scale: likelihood (1-5) x impact (1-5) = score. Bands used in this course exercise: 1-4 Low, 5-9 Medium, 10-16 High, 17-25 Critical. Scores are ordinal judgements, not money or probabilities.

ID	Asset / threat event	Observed weakness (evidence)	L	I	Score	Owner (simulated)
R1	Legacy endpoint :8080 - misuse of an unneeded service	Open on 0.0.0.0:8080, no business need (baseline-ports, baseline-legacy)	4	3	12 High	IT Operations Manager
R2	/archive records - unauthorised disclosure	Directory listing on; file downloadable (baseline-listing, baseline-file)	4	4	16 High	Data Owner
R3	Server network exposure - any host reaches services	No firewall; any source reaches :80/:8080 (baseline-ufw)	4	3	12 High	Security Lead
R4	Portal content - accidental deletion/outage	No backup existed before treatment	3	3	9 Medium	Service Owner

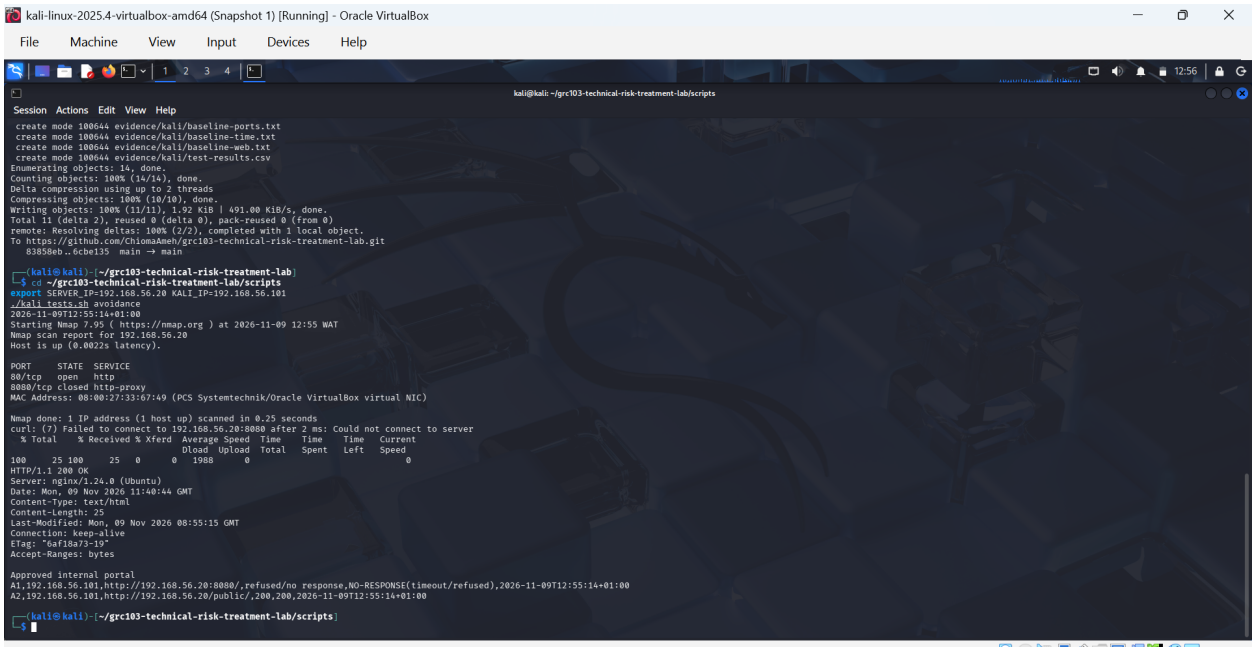
3. Avoidance and service continuity (CHG-01)

Decision. The legacy endpoint has no business purpose, so the activity is avoided: `sudo systemctl disable --now grc-legacy` (script u2_avoid.sh, 9 Nov 11:38:49 UTC, Ubuntu clock). The approved Nginx portal on port 80 was left untouched.

Check	Before (baseline)	After (treated)
Port 8080 (nmap)	open	closed
Legacy endpoint (curl :8080)	200 'Legacy training endpoint'	Could not connect (A1 = no response)
Service state (Ubuntu)	active	inactive / disabled
Approved portal /public/	(available)	200 'Approved internal portal' (A2 = 200)
ss -lntp	8080 and 80 listening	only 80 listening



Screenshot 09 - Ubuntu: service inactive and disabled; port 8080 gone, port 80 still listening.



Screenshot 10 - Kali: 8080 closed (A1), portal still 200 (A2).

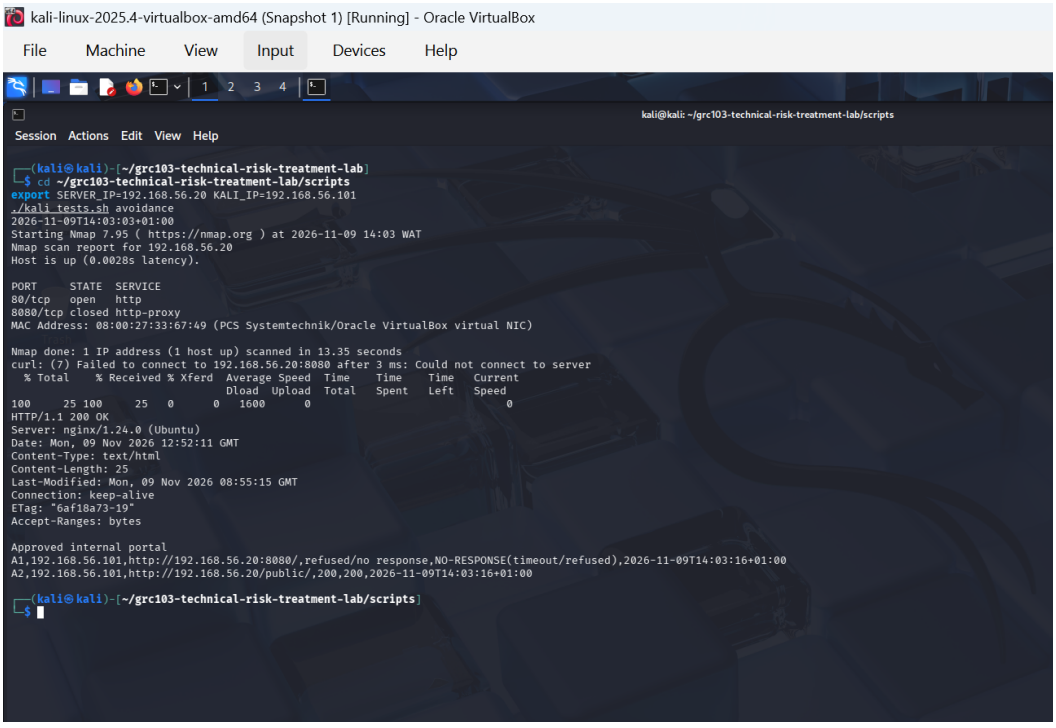
Rollback test. The service was re-enabled at 12:44:59 UTC (Ubuntu clock): port 8080 listened again and Kali received 'Legacy training endpoint'. It was disabled again at 12:48:37 UTC and a final Kali test confirmed 8080 closed and the portal 200 (screenshots 09b, 09c, 10b, 10c).

```
chioma@ubuntu:~$ sudo ls -R /var/www/grc-lab
/var/www/grc-lab:
archive  public

/var/www/grc-lab/archive:
dummy-records.txt

/var/www/grc-lab/public:
index.html
chioma@ubuntu:~$ cat /etc/nginx/sites-available/grc-lab
server {
  listen 80;
  server_name _;
  root /var/www/grc-lab;
  access_log /var/log/nginx/grc_access.log combined;
  error_log /var/log/nginx/grc_error.log;
  location / { autoindex on; }
}
chioma@ubuntu:~$ sudo systemctl enable --now grc-legacy
Created symlink /etc/systemd/system/multi-user.target.wants/grc-legacy.service → /etc/systemd/system/grc-legacy.service.
chioma@ubuntu:~$ date --iso-8601=seconds
2026-11-09T12:44:59+00:00
chioma@ubuntu:~$ sudo ss -lntp | grep 8080
LISTEN 0      5            0.0.0.0:8080       0.0.0.0:*    users:(("python3",pid=1824,fd=3))
chioma@ubuntu:~$ sudo systemctl disable --now grc-legacy
Removed "/etc/systemd/system/multi-user.target.wants/grc-legacy.service".
chioma@ubuntu:~$ date --iso-8601=seconds
2026-11-09T12:48:37+00:00
chioma@ubuntu:~$ sudo ss -lntp | grep 8080
chioma@ubuntu:~$
```

Screenshot 09b - rollback: enabled (8080 listening) then disabled (8080 gone).



Screenshot 10c - final state after rollback test: 8080 closed, portal 200.

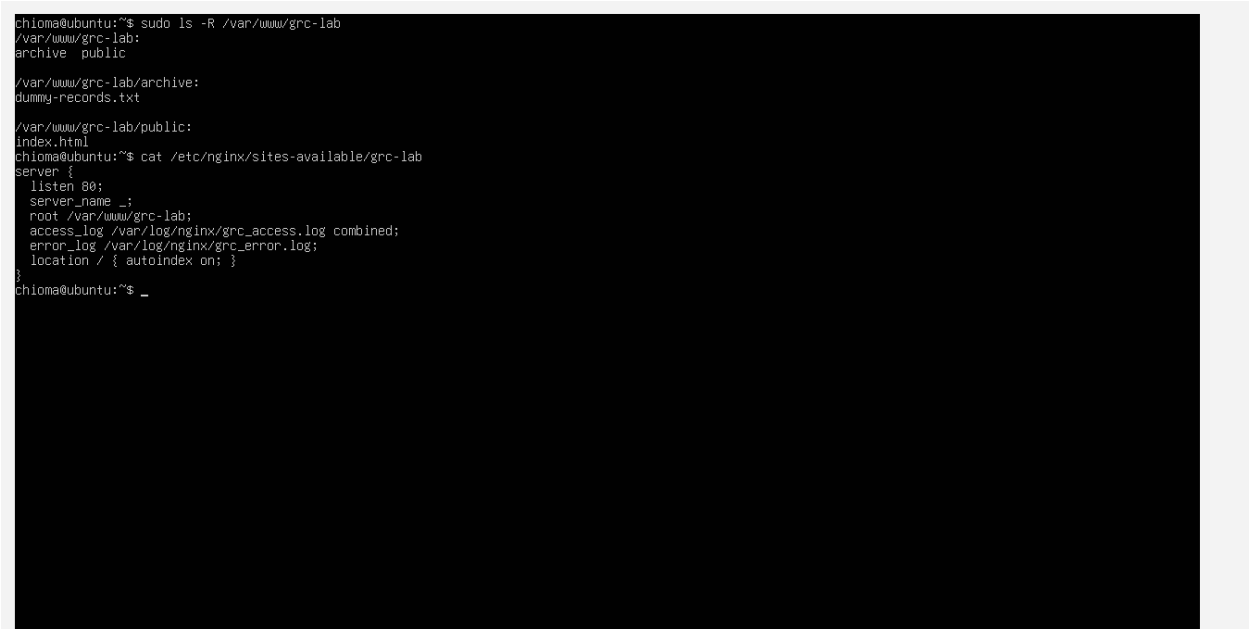
Why avoidance does not eliminate all risk. Retiring the legacy workflow removes only the exposure created by that workflow. The Nginx service on port 80, the operating system, plain-HTTP traffic, the data held in the web root and the possibility of file loss are separate risks that remain and need their own controls (R2 to R4).

4. Archive protection and source-based firewall

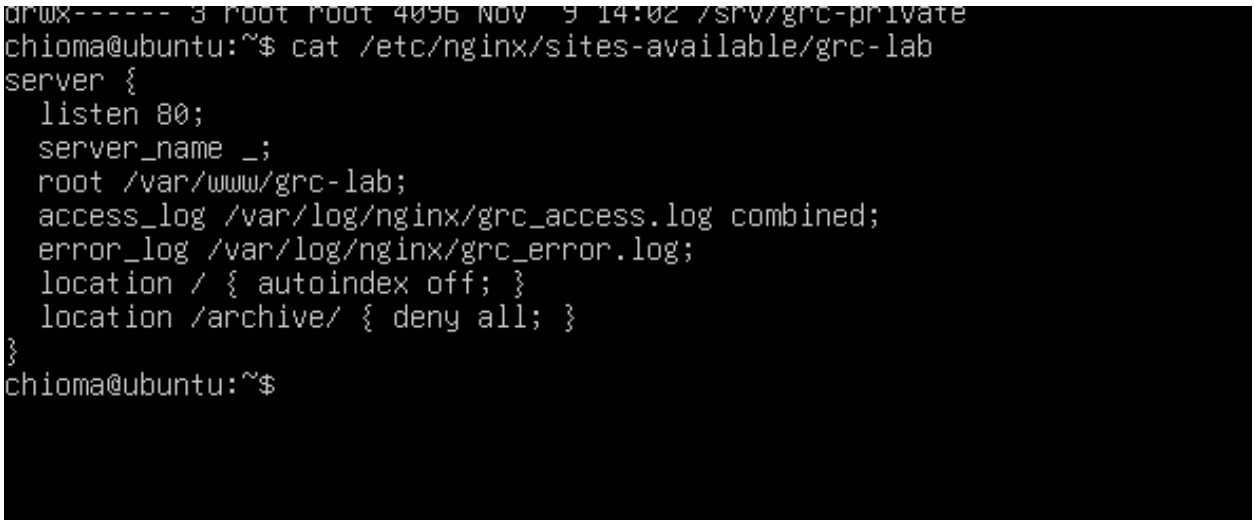
4.1 Archive hardening (CHG-02)

Before: the archive sat inside the web root (`/var/www/grc-lab/archive`) with `autoindex on` (screenshot 08a). Treatment (script u3_archive.sh, 9 Nov ~14:02 Ubuntu clock): the directory was moved to `/srv/grc-private` (mode `drwx------ root root`), `autoindex off` was set, and `location /archive/ { deny all; }` was added; Nginx config test passed and the service was reloaded.

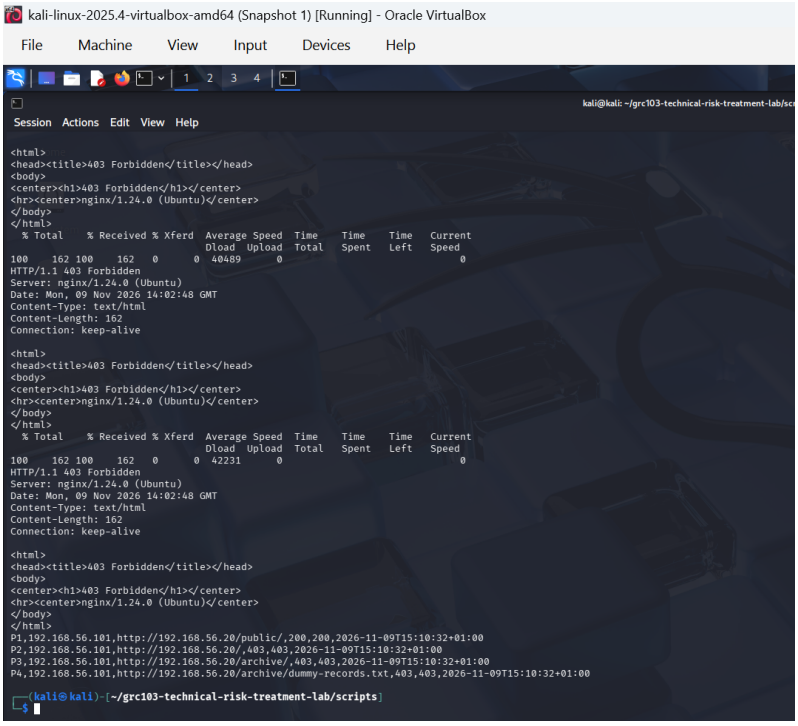
Test	Before	After
GET /public/	200	200 (P1)
GET /	200 (listing)	403 (P2)
GET /archive/	200 (listing)	403 (P3)
GET /archive/dummy-records.txt	200 (file)	403 (P4)



Screenshot 08a - before: archive inside the web root; autoindex on.



Screenshot 11 - after: /srv/grc-private is drwx------ root root; autoindex off; deny all for /archive/.

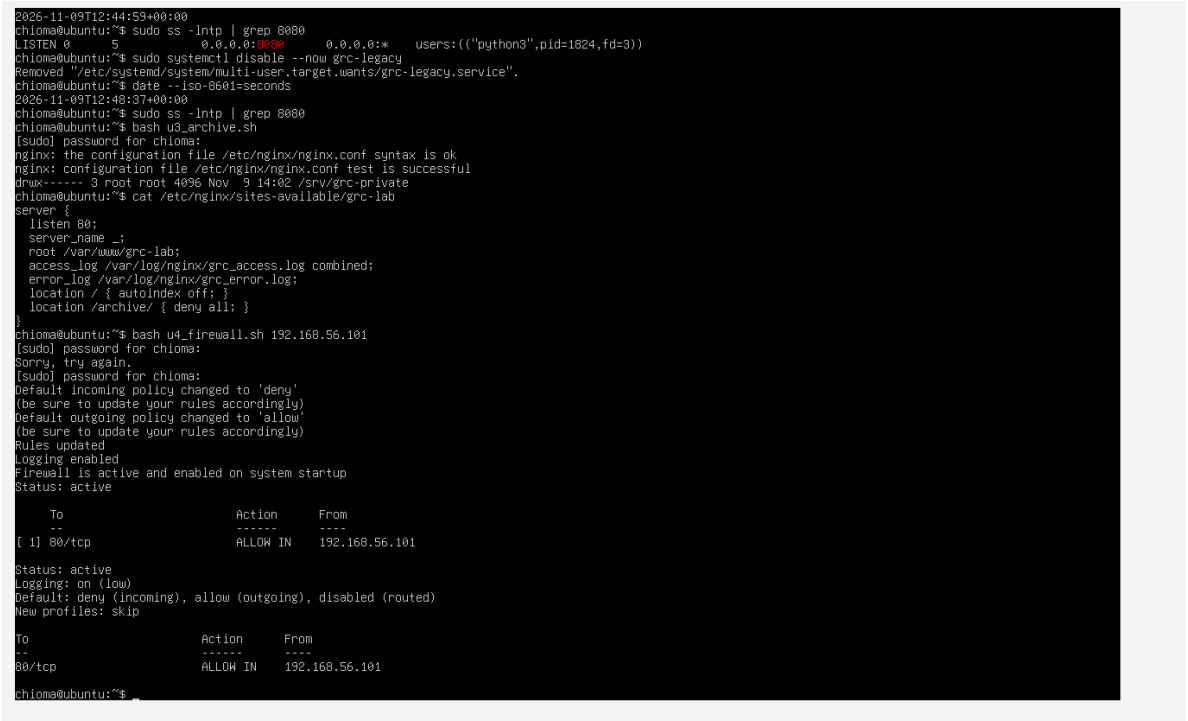


Screenshot 12b - Kali results: /public/ 200; /, /archive/ and the file = 403.

Why disabling directory listing alone is not enough. `autoindex off` only stops Nginx generating a file list. If a visitor knows or guesses the exact file URL, Nginx still serves the file while it remains inside the web root. Real protection needs the file moved out of the web root, restrictive permissions, and an explicit deny.

4.2 Source-based firewall (CHG-03)

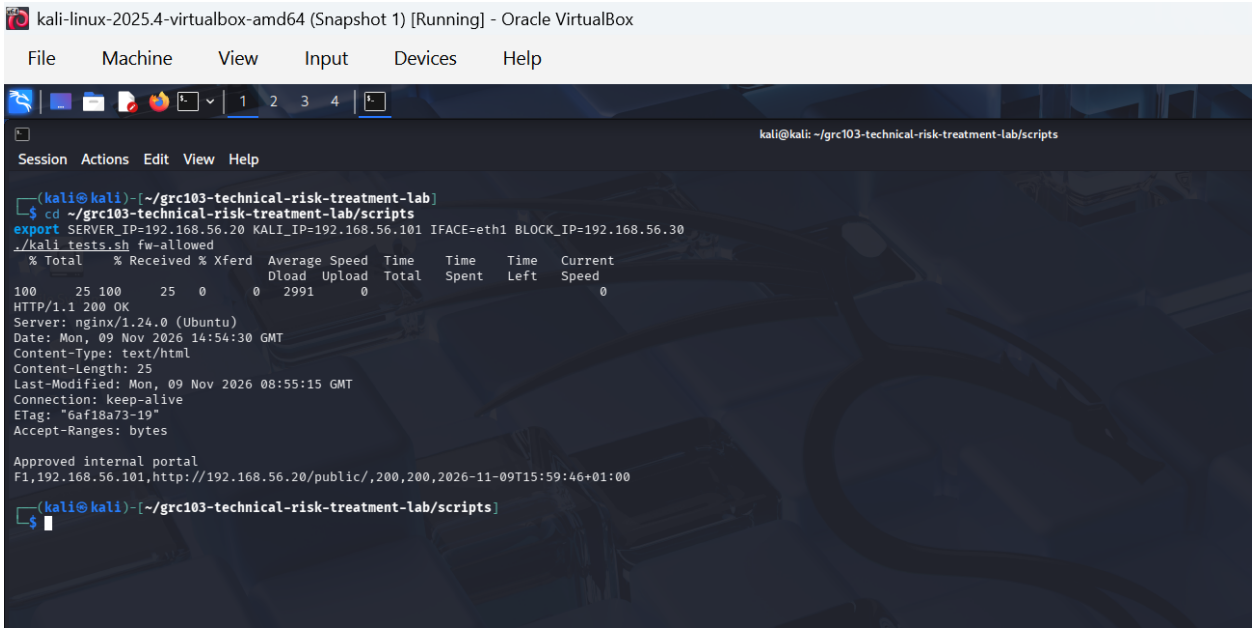
UFW was configured on the VM console: default deny incoming, default allow outgoing, allow only 192.168.56.101 to tcp/80, logging on, then enabled (script u4_firewall.sh). Resulting rule: `80/tcp ALLOW IN 192.168.56.101`; default deny (incoming); logging low.



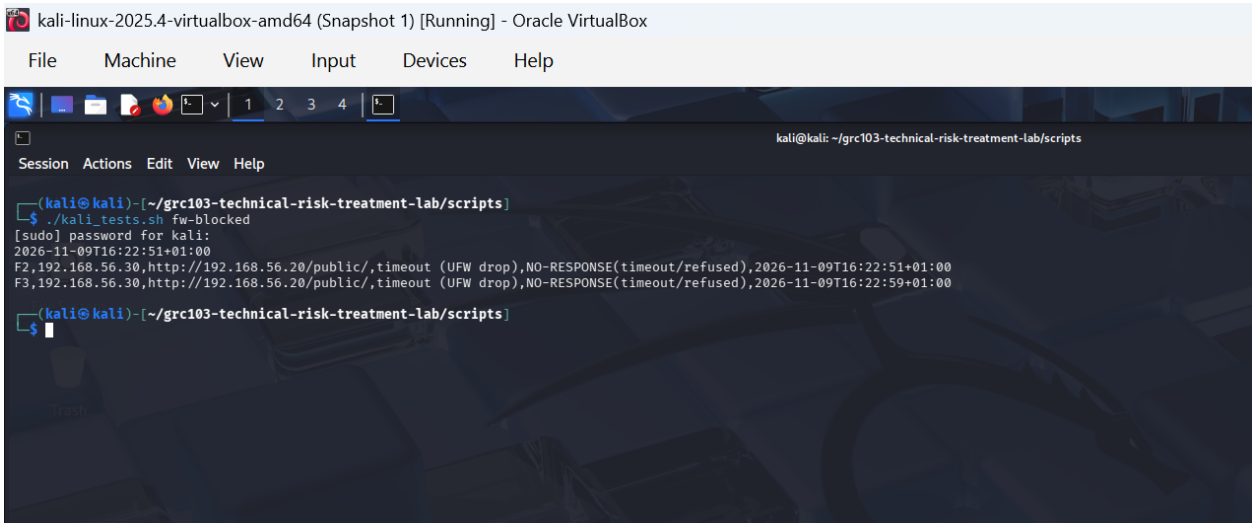
Screenshot 13 - UFW active, default deny (incoming), single allowed source 192.168.56.101 to 80/tcp (one mistyped sudo password is visible and harmless).

Test	Source	Expected	Actual	Kali timestamp (UTC+1)
F1	192.168.56.101 (approved)	200	200	2026-11-09T15:59:46

Test	Source	Expected	Actual	Kali timestamp (UTC+1)
F2	192.168.56.30 (unapproved)	timeout	no response	2026-11-09T16:22:51
F3	192.168.56.30 (unapproved)	timeout	no response	2026-11-09T16:22:59



Screenshot 14a - approved source receives HTTP 200 (F1).

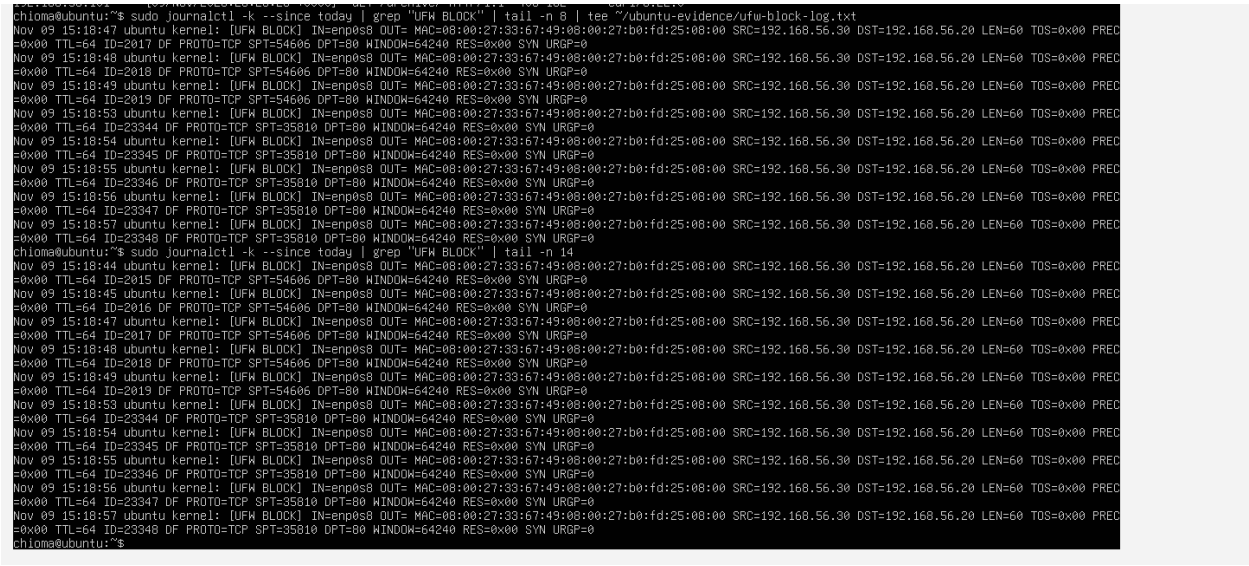


Screenshot 14b - unapproved source 192.168.56.30 gets no response (F2, F3).

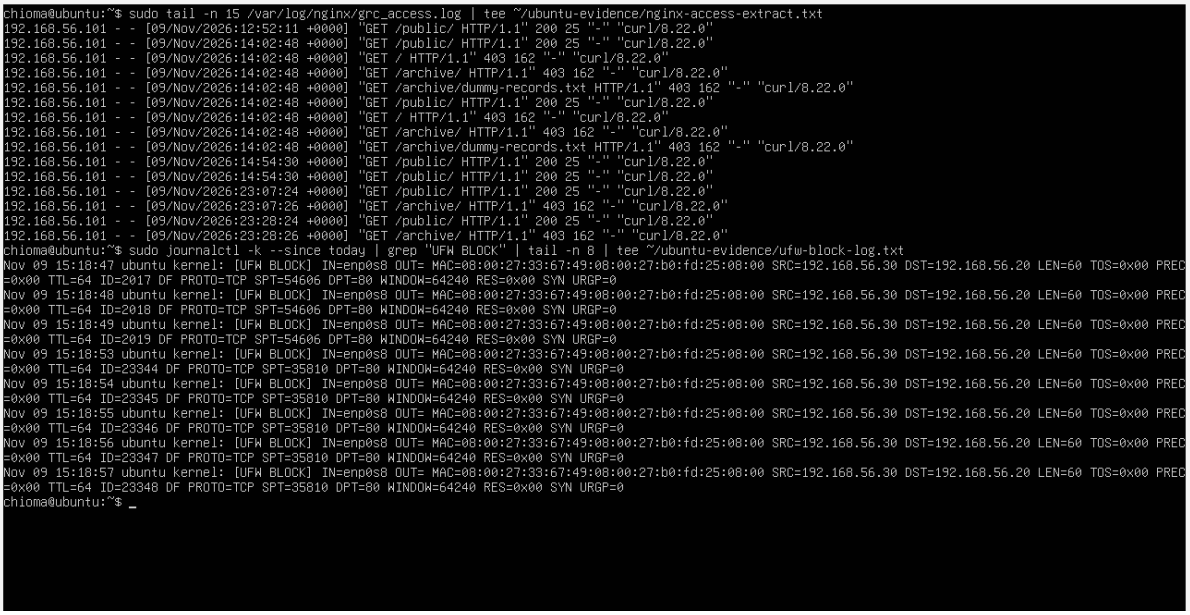
5. Log correlation

Test	Source	Request	Expected	Actual	Kali time (UTC+1)	Ubuntu log line (Ubuntu clock)	Offset
A2	101	/public/	200	200	11-09 14:03:16	grc_access.log 12:52:11 GET /public/ 200	11 m 05 s
P1	101	/public/	200	200	11-09 15:10:32	14:02:48 GET /public/ 200	7 m 44 s
P2	101	/	403	403	11-09 15:10:32	14:02:48 GET / 403	7 m 44 s
P3	101	/archive/	403	403	11-09 15:10:32	14:02:48 GET /archive/ 403	7 m 44 s
P4	101	/archive/dummy-records.txt	403	403	11-09 15:10:32	14:02:48 GET ...dummy-records.txt 403	7 m 44 s
F1	101	/public/	200	200	11-09 15:59:46	14:54:30 GET /public/ 200	5 m 16 s
F2	30	/public/	timeout	no resp.	11-09 16:22:51	kernel [UFW BLOCK] SRC=192.168.56.30 DPT=80 SYN, 15:18:44,45,47,48,49	4 m 07 s
F3	30	/public/	timeout	no resp.	11-09 16:22:59	kernel [UFW BLOCK] SRC=192.168.56.30 DPT=80 SYN, 15:18:53-57	4 m 06 s
L1/L2 run 1	101	/public/, /archive/	200, 403	200, 403	11-10 08:53:17 / :19	23:07:24 / :26 (200 / 403)	8 h 45 m 53 s
L1/L2 run 2	101	/public/, /archive/	200, 403	200, 403	11-10 09:25:26 / :28	23:28:24 / :26 (200 / 403)	8 h 57 m 02 s

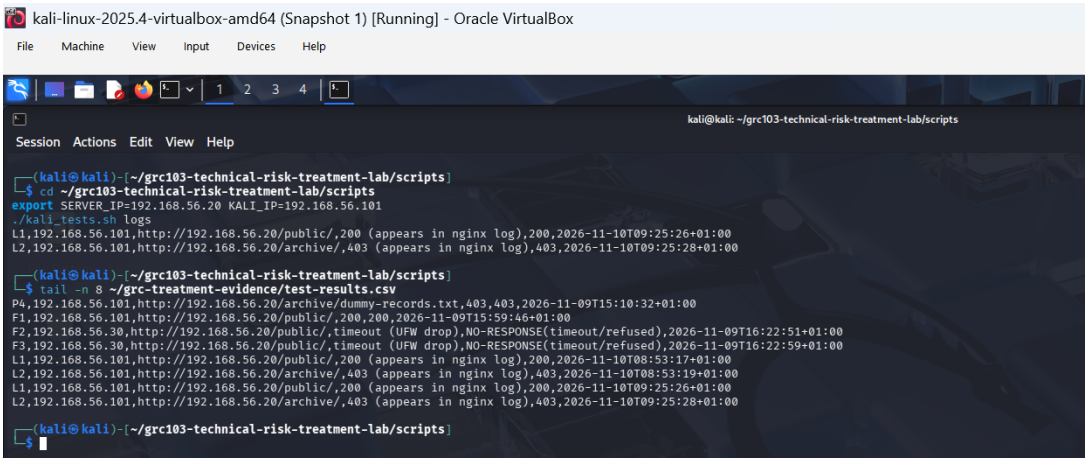
Source '101' = 192.168.56.101 (approved Kali); '30' = 192.168.56.30 (unapproved). Offset = Kali UTC minus Ubuntu clock, measured from the server *Date* header or matched log lines.



Screenshot 15c - kernel log: [UFW BLOCK] SRC=192.168.56.30 DST=192.168.56.20 DPT=80 (SYN only), two attempts at 15:18:44-49 and 15:18:53-57.



Screenshot 15 - Nginx access log: only 192.168.56.101 appears (200 for /public/, 403 for protected paths); no entry for 192.168.56.30.

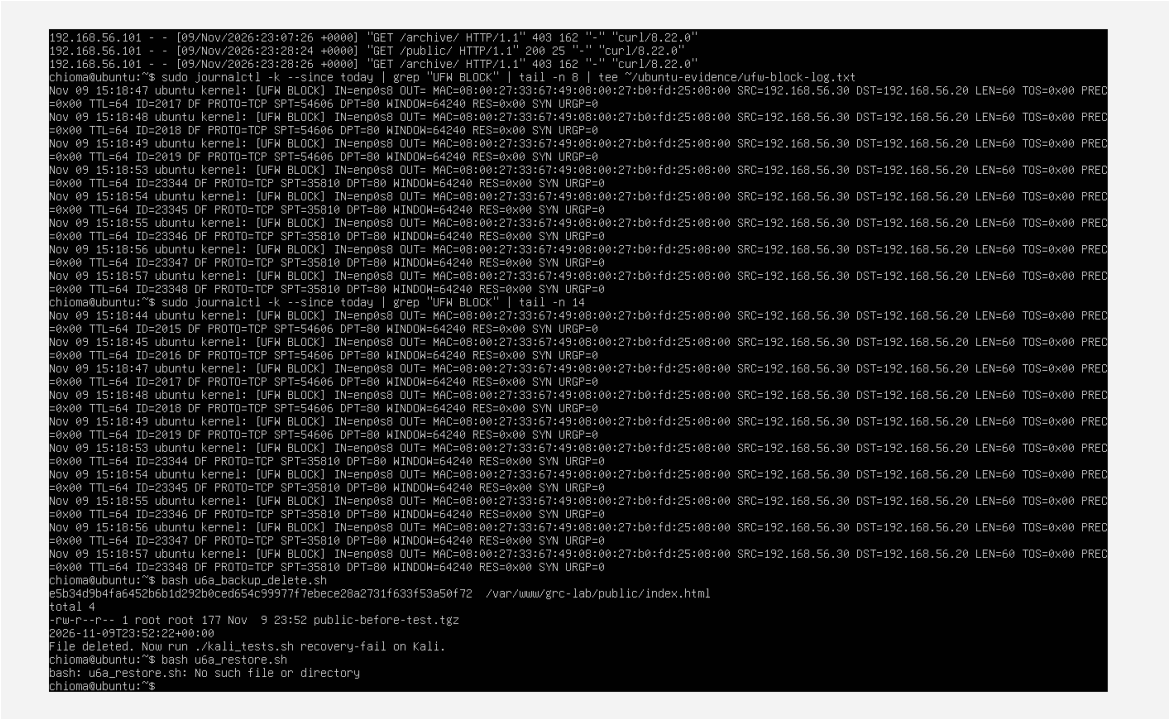


Screenshot 15b - Kali test-results.csv rows F2, F3, L1, L2 used to match the log lines.

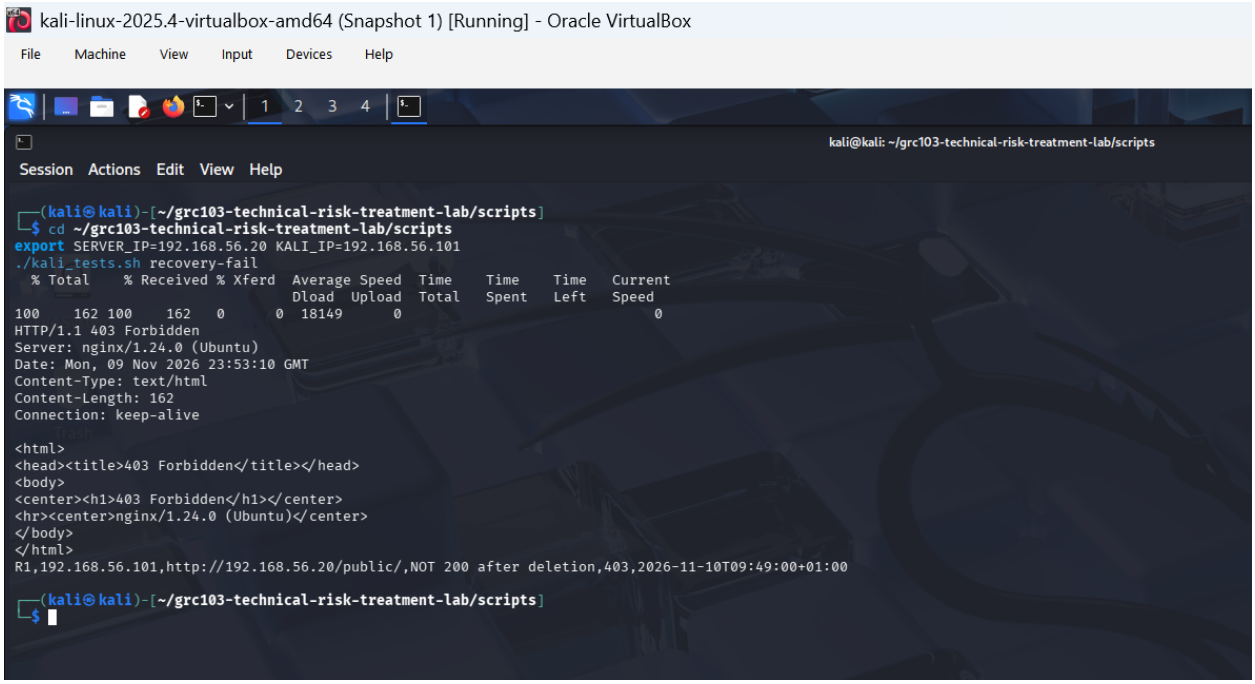
Which requests appear in the Nginx logs, and why blocked traffic does not. Nginx records only requests that reach it: the approved Kali client's /public/ (200) and the protected paths (403). UFW (netfilter in the kernel) drops the unapproved source's TCP SYN packets before a connection reaches Nginx, so no Nginx entry exists for 192.168.56.30; the evidence of the block is the kernel log (`[UFW BLOCK]`, SYN flag only, the handshake never completed) and the client timeout. This is the expected behaviour of a network-layer control.

6. Backup, simulated file loss and verified restoration

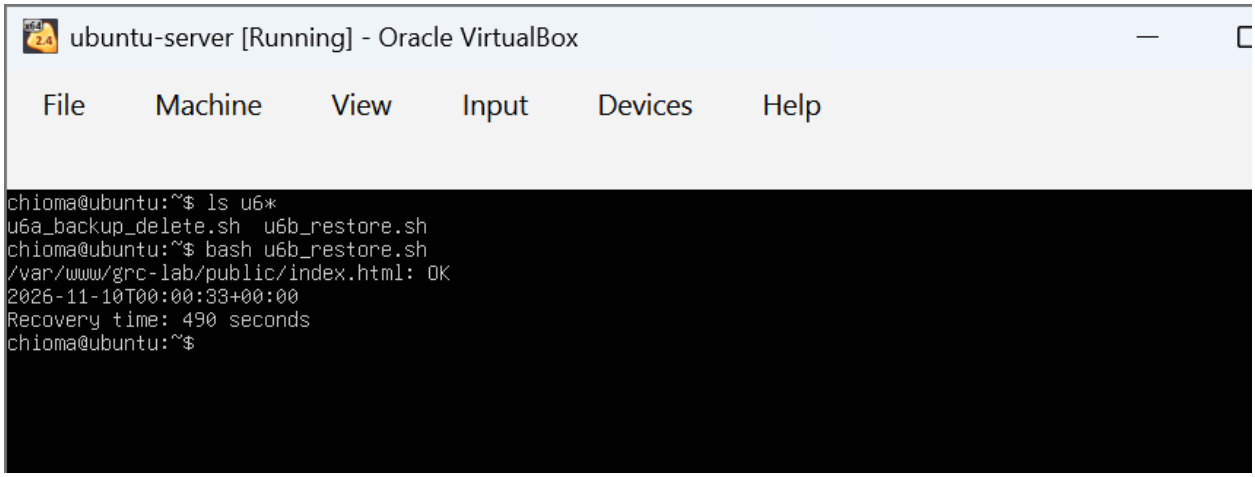
Step	Evidence
Backup created	/srv/grc-backups/public-before-test.tgz (177 bytes; directory mode 700), 9 Nov 23:52 (Ubuntu clock)
Hash before	e5b34d9b4fa6452b6b1d292b0ced654c99977f7ebece28a2731f633f53a50f72 /var/www/grc-lab/public/index.html
Simulated loss	index.html deleted at 2026-11-09T23:52:22+00:00 (Ubuntu clock)
Impact check	Kali /public/ returned 403 (R1, 2026-11-10T09:49:00+01:00) - not 200
Restore	Extracted from the tarball; `sha256sum -c` = **OK**; completed 2026-11-10T00:00:33+00:00
Availability check	Kali /public/ returned 200 'Approved internal portal' (R2, 2026-11-10T09:57:41+01:00)
Observed recovery time	**490 seconds** from deletion to restored and verified file



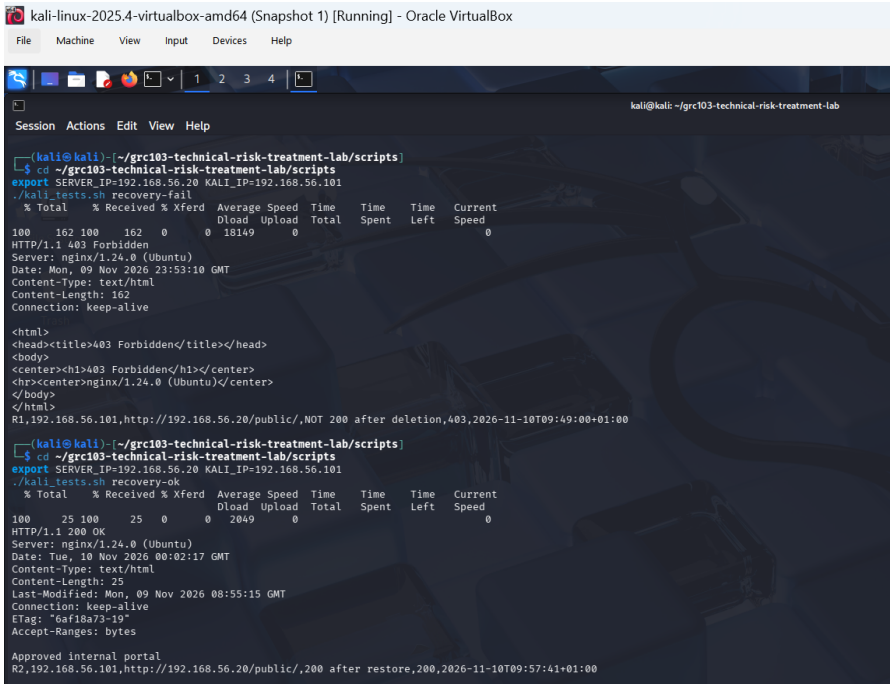
Screenshot 16 - backup, SHA-256, deletion start time (a mistyped restore command, u6a_restore.sh, is visible and harmless).



Screenshot 16b - after deletion the portal is not served (403).



Screenshot 17 - restore: hash OK, end time, recovery time 490 seconds.



Screenshot 17c - after restore the portal returns 200 (R2).

Interpretation of the 490 seconds. It includes the Kali availability check and a mistyped command, so it overstates the time a scripted restore needs (the restore command itself ran in about a second). It is a measured figure for this exercise, not a service-level commitment.

Same-host backup limitation. The tarball lives on the same server. It protects against accidental deletion, but it is lost together with the host if the disk fails, the VM is destroyed, or an attacker or ransomware compromises the host. Off-host (ideally offline or immutable) copies are needed for host-loss scenarios - the reason for the transfer option in Section 7.

7. Treatment decisions, costs, residual risk and governance

All approvals below are **simulated**. Prices and loss estimates are **assumptions**, separate from the measured lab results.

7.1 Decision records

Strategy	Decision and rationale	Evidence	Owner / review
Avoidance (R1)	Retire the legacy endpoint; the activity has no business value so the exposure is removed at no running cost. Limit: only that workflow's risk is avoided.	Sections 2-3	IT Operations Manager; daily drift check
Mitigation (R2, R3, R4)	Preventive: archive moved out of web root, root-only permissions, explicit deny; UFW default-deny with one allowed source. Detective: Nginx and UFW logs. Corrective: backup with hash-verified restore.	Sections 4-6	Data Owner / Security Lead / Service Owner
Transfer (R4, host loss)	Managed off-host backup (fictional offer: $120 setup + $20/month). Provider: scheduled encrypted off-site backups, versions, restore support. Customer keeps: data classification, credentials, quarterly restoration tests with SHA-256 and recorded time, evidence kept 12 months. The provider restores backups only; it does not prevent deletion, compromise or misconfiguration at source. A contract or insurance does not remove the technical risk. *Draft clause:* 'The Provider shall perform daily encrypted off-site backups of the Customer Portal data set, retain 30 days of versions and complete a Customer-requested restore within 4 business hours. The Customer remains responsible for data classification, access credentials and quarterly restoration tests. The Provider's liability is limited to the fees paid for the affected period.' No purchase was made.	Section 6 limitation	Service Owner
Acceptance (plain HTTP)	Accept temporarily: dummy data only, isolated host-only network, single allowed source. Residual L2 x I2 = 4 Low. Proposed expiry 14 days; review before expiry. Re-evaluate immediately if real or personal data appears, if any external or bridged connectivity is added, if more clients or a wider network are allowed, or if the portal's purpose changes - then acceptance is void and TLS (Option C) is implemented.	Sections 2, 4	Service Owner (simulated approval)

7.2 Costs (fictional first-year prices - assumptions)

First-year cost = setup + labour + annual recurring cost.

Option	Calculation	First-year cost
A Hardening	4 h x $25 + $50 annual maintenance	$150
B Managed backup	$120 setup + $20 x 12 months	$360
C TLS deployment	3 h x $25 + $25 annual maintenance	$100
Chosen combination A + B + C	150 + 360 + 100	**$610**

Excluded costs: staff training, monitoring time, hardware/hypervisor, downtime cost, licences, audit time, end-of-life costs. A is already implemented and cheapest per risk removed; C removes the cleartext-HTTP weakness and ends the need for acceptance; B covers the host-loss gap a local backup cannot.

Illustrative backup scenario (all figures assumed, not measured): annual rate of occurrence 0.2; loss per event $5,000 without tested recovery and $1,000 with it.

Quantity	Calculation	Result
Baseline ALE	0.2 x 5,000	$1,000
Residual ALE	0.2 x 1,000	$200
Annual benefit	1,000 - 200	$800
First-year net benefit, Option B	800 - 360	$440

The recovery test does not prove these financial figures. Benefits of A, B and C overlap, so they are not added together, and ordinal risk scores are not converted into dollars. The calculation workbook is in the repository (calculations/cost_analysis.xlsx).

7.3 Residual risk after treatment

ID	Baseline	Residual L x I	Residual	Basis (tested = observed in this lab)	Remaining weakness	Review trigger
R1	4x3 = 12 High	1 x 3	3 Low	Tested: 8080 closed, rollback proven	Service could be re-enabled by mistake	Any new open port (daily scan)

ID	Baseline	Residual L x I	Residual	Basis (tested = observed in this lab)	Remaining weakness	Review trigger
R2	4x4 = 16 High	2 x 4	8 Medium	Tested: 403 for /, /archive/, file	Plain HTTP; allow-list relies on source IP	Real data stored; web-root change
R3	4x3 = 12 High	2 x 3	6 Medium	Tested: approved 200, unapproved dropped + UFW BLOCK log	Source IP can be spoofed on a shared network; no TLS	New client/subnet; rule change
R4	3x3 = 9 Medium	2 x 3	6 Medium	Tested: restore with SHA-256 OK, 490 s	Backup is on the same host	Failed restore test; host change

8. Change and rollback records (approvals simulated)

Field	CHG-01 Retire legacy service	CHG-02 Archive protection	CHG-03 UFW source restriction	CHG-04 Backup/restore exercise
Change	Disable grc-legacy (:8080)	Move archive to /srv/grc-private; autoindex off; deny /archive/	Default deny incoming; allow 192.168.56.101 to tcp/80	tar backup + SHA-256; delete; restore
Business impact	None; endpoint unused	None for /public/; old URLs return 403	Only the approved client reaches the portal	Intentional short portal outage (lab)
Approver (simulated)	IT Operations Manager	Data Owner	Security Lead	Service Owner
Executed (Ubuntu clock)	9 Nov 11:38:49 UTC	9 Nov ~14:02 UTC	9 Nov, between 14:02 and 14:54 UTC	9 Nov 23:52:22 UTC; restore done 10 Nov 00:00:33 UTC
Post-test	8080 closed; portal 200	/public/ 200; /, /archive/, file 403	Approved 200; unapproved timed out + UFW BLOCK	hash OK; portal 200
Rollback	systemctl enable --now grc-legacy	restore baseline nginx conf; move archive back; reload	sudo ufw disable (console)	restore from tarball
Rollback tested?	**Yes** (12:44:59 on, 12:48:37 off; screenshots 09b, 10b)	Documented, not tested	Documented, not tested	Yes (restore performed)
Final state	Legacy disabled	Archive private	UFW active	Portal restored



Screenshot 17b - final state: nginx active, grc-legacy disabled, UFW active with the single allow rule, only port 80 listening.

9. Monitoring and operational handover

Measured in the lab: the tests and the 490-second recovery. **Proposed (not measured):** everything in this table.

#	Check	Owner	Frequency	Threshold	Escalation
M1	Portal availability: curl /public/ from the approved client	Service Owner	Every 5 min	Non-200 twice in a row	Page IT Ops; start restore after 15 min
M2	Unexpected open ports: nmap against the approved list (80 only)	Security Lead	Daily	Any port other than 80	Incident ticket within 1 hour; close port, investigate
M3	Recovery test: restore + sha256sum -c	Service Owner	Monthly (quarterly with managed backup)	Hash mismatch or recovery over 15 min	Fix backup process within 5 business days; re-test

#	Check	Owner	Frequency	Threshold	Escalation
M4	Drift: systemctl is-enabled grc-legacy must not be enabled; 8080 closed	IT Ops Manager	Daily	Enabled/active or 8080 open	Treat as change-control breach; disable and review
M5	UFW active with expected rules (ufw status numbered)	Security Lead	Daily	Inactive or extra allow rules	Restore baseline ruleset; open incident

Leading indicators: M2, M4, M5 (exposure and drift). Lagging indicators: portal downtime minutes and failed restore tests.

10. Management summary

Situation. Northbridge Services' internal document server exposed an unnecessary legacy service (port 8080) and a browsable directory of records, with no network restrictions and no backup.

What was done and proved (measured). The legacy service was retired: port 8080 went from open to closed while the approved portal stayed at HTTP 200, and the change was rolled back and re-applied successfully. The archive was moved out of the web root: direct access to the records file went from 200 to 403. A source-based firewall now allows only the approved client: the approved source received 200, the unapproved source timed out, and the kernel log recorded [UFW BLOCK] for it while Nginx recorded nothing. A deleted portal file was restored from backup with a matching SHA-256 hash in 490 seconds (including manual steps).

Residual risk. Plain HTTP remains; the allow-list relies on the source IP; the backup is on the same host. Residual scores: R1 3 Low, R2 8 Medium, R3 6 Medium, R4 6 Medium.

Recommendation (assumption-based costs). Adopt Option A (hardening, done), Option C (TLS, $100) and Option B (managed off-host backup, $360): total first-year cost $610. Accept plain HTTP only temporarily (14 days, dummy data only, simulated approval) until TLS is in place.

Monitoring. Five checks - availability, open ports, recovery test, retired-service drift, firewall state - each with an owner, threshold and escalation path (Section 9).

Decisions needed. Approve the 14-day acceptance and the TLS plus managed-backup budget (simulated).

Measured results come from the laboratory; approvals, financial figures and the managed-backup offer are simulated or assumed.

11. Evidence index

Lab step	Evidence in repository (evidence/ and records/)
Setup	screenshots 00a-00e, 01a, 02, 04, 05 (Ubuntu build, host-only network, NAT down)
Baseline (Step 4)	kali/baseline-*.txt, ubuntu/baseline-ufw.txt, baseline-ss.txt, screenshots 06, 07, 08a
Risk register (Step 5)	this report Section 2; records/01_risk_register.md
Avoidance (Step 6)	kali/avoidance-*.txt, ubuntu/avoidance-*.txt, screenshots 09, 09b, 09c, 10, 10b, 10c
Archive (Step 7)	kali/archive-*.txt, ubuntu/archive-permissions.txt, nginx-grc-lab-final.conf, screenshots 11, 12, 12b
Firewall (Step 8)	ubuntu/ufw-status-numbered.txt, ufw-status-verbose.txt, kali/firewall-*.txt, screenshots 13, 14a, 14b
Logs (Step 9)	ubuntu/nginx-access-extract.txt, ufw-block-log.txt, records/04_evidence_table.md, screenshots 15, 15b, 15c
Backup/recovery (Step 10)	ubuntu/backup-*.txt, recovery-*.txt, kali/recovery-*.txt, screenshots 16, 16b, 17, 17c
Decisions, costs (Steps 11-12)	this report Sections 7-8; records/03, 05, 06; calculations/cost_analysis.xlsx
Scripts	scripts/u1_build.sh ... u7_ship.sh, scripts/kali_tests.sh

12. Limitations

- Single approved source IP is a weak identity control on a shared network (spoofing is possible); production would add authentication and TLS.

- Ubuntu's clock was unsynchronised and drifted; correlation used measured offsets plus request sequence and spacing.

- The recovery time includes manual steps and a mistyped command; the backup was stored on the same host.

- Rollback for CHG-02 and CHG-03 is documented but was not executed; rollback for CHG-01 and CHG-04 was executed.

- Costs, ALE figures, the managed-backup contract terms and all approvals are simulated or assumed.